

Security / JWT 확인용 프론트

http://localhost:8080 로 절대 URL 직접 호출 — proxy를 쓰지 않으므로 모든 요청이 cross-origin이고 preflight(OPTIONS)가 실제로 발생합니다.
개발자도구 **Network** 탭에 OPTIONS가 먼저 찍히면 CORS(F6)가 살아 있는 것입니다.

F1. 로그인 & 토큰 발급

POST /api/member/login

이메일

user1@aaa.com

비밀번호

....

로그인

틀린 비밀번호로 로그인

토큰 삭제

테스트 계정 (MemberRepositoryTests.회원_2명_생성 실행 시 만들어집니다)

· user1@aaa.com / 1111 — ROLE_USER · ADMIN 전용 API 호출 시 403이 나와 정상

· admin@aaa.com / 1111 — ROLE_USER + ROLE_ADMIN · 모든 API 통과

현재 토큰 상태

accessToken

9분 31초 남음

eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJzb2NpYWwiOmZhbHN1LCJwdyI6IiQyYSQxMCRqc3NneEhOUUYzTWNndnQxNFNuWEF1T0xOc3RRQXEzRkNOWX1rcTNxNUFDM2ZRQ24yWVZkcSIsIm5pY2tuYW11IjoivVNFUjEiLCJyb2x1TmFtZXMiOlsiVWNFUjdlLCJlbWFPbCI6InVzZXIxQGFnYS5jb20iLCJpYXQiOiJE3ODU5ODEwNDMsImV4cCI6MTc4NTk4MTY0M30.HzUJhAmg-MivVqCxLW1jRwRFSXjKdTJraFVSTKJrNM

refreshToken

보관 중

eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJzb2NpYWwiOmZhbHN1LCJwdyI6IiQyYSQxMCRqc3NneEhOUUYzTWNndnQxNFNuWEF1T0xOc3RRQXEzRkNOWX1rcTNxNUFDM2ZRQ24yWVZkcSIsIm5pY2tuYW11IjoivVNFUjEiLCJyb2x1TmFtZXMiOlsiVWNFUjdlLCJlbWFPbCI6InVzZXIxQGFnYS5jb20iLCJpYXQiOiJE3ODU5NDZgxmZksImV4cCI6MTc4NjA2NDUzOX0.NG3f87-tES0rJqdtYe6-gadKFQec7CjQkqf7YtHuyKY

payload (claims)

```
{
  "social": false,
  "pw": "$2a$10$jssgxHN0F3Mcvgt14SnXAu0LNst0Aq3FCNYyq3q5AC3f0Cn2YVdq",
  "nickname": "USER1",
  "roleNames": [
    "USER"
  ],
  "email": "user1@aaa.com",
  "iat": 1785981043,
  "exp": 1785981643
}
```

⚠ payload에 pw(BCrypt 해시)가 들어 있습니다. JWT는 서명만 될 뿐 암호화되지 않아 누구나 Base64로 열어볼 수 있습니다 — 알려진 결함 **K5**.

F3 토큰 검사 · F4 인가			
테스트	기대 결과		
보호 API 호출 (토큰 O) GET /api/sample/user	F3	200 · 인증 주체(email·권한) 반환	호출
보호 API 호출 (토큰 X) GET /api/sample/user · Authorization 헤더 없음	F3	ERROR_ACCESS_TOKEN	호출
위조 토큰으로 호출 토큰 뒤에 문자열을 덧붙여 서명을 깨뜨림	F3	ERROR_ACCESS_TOKEN	호출
필터 제외 경로 호출 GET /api/sample/public · shouldNotFilter 대상	F3	토큰 없이 200	호출
권한 부족 API 호출 GET /api/sample/admin · @PreAuthorize hasRole('ADMIN')	F4	user1이면 403 ERROR_ACCESSDENIED · admin이면 200	호출

F5. 토큰 갱신

/api/member/refresh

refresh 호출

refreshToken 없이 호출

accessToken 강제 만료

· accessToken이 유효하면 기존 토큰 쌍을 그대로 돌려줍니다.

· 강제 만료 후에 눌러야 새 accessToken이 발급됩니다.

· refreshToken 없이 호출하면 NULL_REFRESH가 와야 합니다.

응답 로그

지우기

에러인데 HTTP 200으로 찍히는 것은 정상이 아니라 기록된 결함 **K2 / K3**입니다. 그래서 이 화면은 상태코드가 아니라 본문의 에러 코드로 성공/실패를 판정합니다.

[오전 10:50:43] 갱신 판정

accessToken이 새로 발급되었습니다. (기존 토큰이 만료 상태였음)

[오전 10:50:43] GET /api/member/refresh → HTTP 200

```
{
  "accessToken":
  "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJzb2NpYWwiOmZhbHN1LCJwdyI6IiQyYSQxMCRqc3NneEhOUUYzTWNndnQxNFNuWEF1T0xOc3RRQXEzRkNOWX1rcTNxNUFDM2ZRQ24yWVZkcSIsIm5pY2tuYW11IjoivVNFUjEiLCJyb2x1TmFtZXMiOlsiVWNFUjdlLCJlbWFPbCI6InVzZXIxQGFnYS5jb20iLCJpYXQiOiJE3ODU5NDZgxmZksImV4cCI6MTc4NjA2NDUzOX0.NG3f87-tES0rJqdtYe6-gadKFQec7CjQkqf7YtHuyKY"
  "refreshToken":
  "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJzb2NpYWwiOmZhbHN1LCJwdyI6IiQyYSQxMCRqc3NneEhOUUYzTWNndnQxNFNuWEF1T0xOc3RRQXEzRkNOWX1rcTNxNUFDM2ZRQ24yWVZkcSIsIm5pY2tuYW11IjoivVNFUjEiLCJyb2x1TmFtZXMiOlsiVWNFUjdlLCJlbWFPbCI6InVzZXIxQGFnYS5jb20iLCJpYXQiOiJE3ODU5NDZgxmZksImV4cCI6MTc4NjA2NDUzOX0.NG3f87-tES0rJqdtYe6-gadKFQec7CjQkqf7YtHuyKY"
}
```